XOR SECURE CLOUD

Sổ tay rà soát kỹ thuật hệ thống thông tin cấp độ 4

Bộ 1 dành cho đội kỹ thuật và các đầu mối cung cấp bằng chứng

Nền tảng XOR STACK CLOUD dựa trên OpenStack

DC tại Trung tâm Hạ tầng IDC Cầu Giấy
DR tại Trung tâm Hạ tầng IDC Nam Thăng Long

Bản dự thảo 2.0 ngày 17 tháng 10 năm 2026

Mục tiêu là xác định rõ kiểm soát nào đã triển khai, bằng chứng nào đã có, nội dung nào chưa đủ và ai chịu trách nhiệm bổ sung. Dùng cùng workbook 02_Checklist_ra_soat_XOR_cap_do_4.xlsx; chưa có hạng mục nào được xác nhận đạt chỉ từ việc lập bộ hồ sơ này.

Đầu vào đã xác nhận	Dữ liệu phải bổ sung
Toàn bộ nền tảng cloud và dịch vụ quản trị chung.	Danh mục tài sản, dịch vụ thực tế, phiên bản, số lượng và ranh giới khách hàng.
XOR STACK CLOUD do XOR CLOUD phát triển lại và đóng gói từ OpenStack.	Upstream release, bản dựng XOR, SBOM, cấu hình và kết quả thử.
DC Cầu Giấy; DR Nam Thăng Long; lập hồ sơ lần đầu.	Hợp đồng và tài liệu IDC; phê duyệt thiết kế; pháp nhân, người ký và đầu mối.

Sản phẩm của một đợt rà soát

Workbook đã cập nhật; kho bằng chứng có mã, phiên bản và người xác minh; danh sách thiếu sót có đầu mối và hạn; biên bản kiểm thử; báo cáo kết quả có giới hạn phạm vi. Chỉ chuyển số liệu đã xác nhận sang bộ hồ sơ hành chính.

1 Cách sử dụng checklist

Bước	Thực hiện	Điều kiện kết thúc
1 Chốt phạm vi	Điền phạm vi từng dòng, dịch vụ và hai IDC. Chốt phần Cloud tham khảo tự nguyện.	Không dùng “không áp dụng” để che hạng mục chưa có.
2 Giao việc	Gán cá nhân thực hiện từ đầu mối đề xuất; nhập hạn xử lý.	Mỗi mục có người chịu trách nhiệm rõ ràng.
3 Kiểm tra hiện trạng	Đối chiếu cấu hình, tài liệu, log, quan sát và phép thử.	Phân biệt Chưa xác minh, Chưa triển khai, Một phần, Đầy đủ.
4 Ghi bằng chứng	Đăng ký mã EV, kho lưu, ngày, phiên bản, phạm vi và người thu.	Bằng chứng đọc được, khớp môi trường và không lộ bí mật.
5 Xác nhận	Người kiểm tra độc lập với người thực hiện khi phù hợp ghi kết quả/ngày.	Đạt chỉ khi đáp ứng đủ các ý trong dòng và phạm vi.
6 Khắc phục	Lập hành động, thay đổi theo quy trình và retest.	Giữ kết quả cũ và mới; không xóa dấu vết chưa đạt.

Ý nghĩa trạng thái tổng hợp

“Đủ hồ sơ kiểm tra” cần đồng thời: áp dụng Có, triển khai Đầy đủ, có mã hoặc đường dẫn bằng chứng, kết quả Đạt, có người và ngày kiểm tra. Công thức chỉ kiểm tra dữ liệu khai báo; người xác nhận chịu trách nhiệm về nội dung bằng chứng. Trạng thái này không phải quyết định phê duyệt cấp độ.

“Không áp dụng đã duyệt” cần lý do và văn bản/người có thẩm quyền chấp thuận, người xác nhận và ngày. Nếu chưa chốt phạm vi hoặc chưa có bằng chứng, giữ nguyên trạng thái chờ, không ghi đạt.

2 Phân công và ranh giới rà soát

Nhóm	Chịu trách nhiệm	Bằng chứng chính
Chủ quản và GRC	Phạm vi, căn cứ cấp độ, rủi ro, thẩm quyền và hồ sơ trình.	HS01–HS10, BIA, sổ rủi ro.
Platform và DevSecOps	Bản dựng, control plane, hypervisor, image và pipeline.	CMDB, SBOM, baseline, release, T02/T07/T10/T11.
Network và Storage	Phân vùng, kết nối, dữ liệu, HA và hiệu năng.	LLD, rule, route, ACL, replica, T01/T02/T04/T07.
IAM và quản trị khóa	Định danh, MFA, đặc quyền, khóa và chứng thư.	RBAC, PAM, vòng đời khóa, T03/T04.
SOC và CSIRT	Log, trực giám sát, sự cố, EDR/DLP và diễn tập.	Ma trận nguồn, lịch trực, ticket, T05/T06.
Backup và chỉ huy DR	Bản sao, phụ thuộc phục hồi, failover và failback.	BIA, job, runbook, T08/T09/T10.
IDC và mua sắm	Vật lý, nguồn điện, PCCC, ra vào và nhà cung cấp.	Hồ sơ từng site, SLA, phân định trách nhiệm.
Người kiểm tra	Kiểm tra phạm vi, bằng chứng, kết quả và retest.	Biên bản, kết luận có giới hạn, danh sách tồn tại.

Dịch vụ khách hàng tự quản phải có ma trận trách nhiệm chung. Hạ tầng nền đạt yêu cầu không tự chứng minh ứng dụng, hệ điều hành khách, dữ liệu hoặc tài khoản của khách hàng đã được phê duyệt cùng cấp độ.

3 Thu thập và quản lý bằng chứng

Mỗi bằng chứng dùng mã EV và liên kết tới mã TC, CL, HS hoặc T. Tên tệp gợi ý: EV-001_TC-001_DC_20261017_v1. Ghi ngày giờ, phạm vi, bản dựng, người thu, người xác minh và đường dẫn kho. Tạo bản đã che dữ liệu để đưa vào hồ sơ; giữ bản gốc ở kho có phân quyền và kiểm soát toàn vẹn.

Nguồn	Cách thu	Lưu ý kiểm tra
OpenStack/XOR	Xuất inventory service, endpoint, project/role, network, port, SG, image và volume theo quyền được cấp.	Ghi phiên bản CLI/API và project scope; không xuất token hoặc mật khẩu.
Host/cluster	Thu phiên bản OS/gói, cấu hình đã lọc bí mật, cluster status, route và trạng thái agent.	Bản cấu hình trích phải gắn host, ngày, hash; không dùng ảnh menu làm chứng cứ tính năng đang hoạt động.
IAM/PAM/KMS	Xuất chính sách, vai trò, log mẫu, lịch sử cấp/thu hồi và luân chuyển.	Không đưa khóa riêng, recovery code hoặc secret vào tài liệu.
SOC/backup	Xuất nguồn log, rule, retention, job, mẫu cảnh báo và biên bản restore.	Có số đo thời gian và bản ghi xử lý; ảnh dashboard riêng lẻ chưa đủ.
IDC	Thu hồ sơ nghiệm thu, bảo trì, điện, camera, ra vào và hợp đồng.	Xác minh phạm vi chứng chỉ bao phủ đúng cơ sở/phòng/rack và còn hiệu lực.

Thứ tự ưu tiên bằng chứng

Kết hợp tài liệu đã phê duyệt, cấu hình thực tế, log vận hành và phép thử. Bằng chứng phải trả lời được yêu cầu đã triển khai ở đâu, có hoạt động hay không, ai chịu trách nhiệm và còn hiệu lực tại thời điểm đánh giá. Không thay phép thử bằng cam kết mua sắm hoặc mô tả tính năng sản phẩm.

4 Các mốc kiểm tra định kỳ

Hoạt động	Mốc tối thiểu theo TCVN	Điều khoản
Nhận diện và xem lại hiệu lực xử lý rủi ro	1 lần/6 tháng và khi có thay đổi liên quan	6.1.2.2; 6.1.2.4
Rà thiết bị trái phép, tài sản kết nối, DHCP/IPAM	1 lần/quý	6.2.2.2–6.2.2.4
Danh mục tài khoản và quyền dữ liệu	1 lần/quý	6.6.2.1; 6.4.2.1
Scan toàn hệ thống / tài sản quan trọng	1 lần/6 tháng / 1 lần/quý	6.7.2.1
Máy người dùng và di động được cấp	Kiểm tra/cập nhật vá ít nhất 1 lần/tháng nếu có	6.7.2.2
Rà nhật ký an ninh	1 lần/tháng	6.8.2.1
Lưu nhật ký an ninh / camera phòng máy	Tối thiểu 6 tháng cho mỗi loại	6.8.2.1; A.4.2
Thử phục hồi bản sao	1 lần/6 tháng	6.11.2.5
Rà sơ đồ mạng	1 lần/6 tháng và khi thay đổi	6.12.2.1
Điều chỉnh ngưỡng cảnh báo	1 lần/quý	6.13.2.5
Đào tạo và diễn tập sự cố	1 lần/năm; theo vai trò và thay đổi khi áp dụng	6.14.2; 6.16.2.6; 6.17.2.6
Danh mục thư viện/thành phần bên thứ ba	1 lần/quý	6.16.2.4
Pentest bên trong và bên ngoài	Mỗi loại ít nhất 1 lần/năm	6.18.2.2; 6.18.2.5

Các quy trình và danh mục còn có mốc rà soát riêng tại từng dòng TCVN. RPO/RTO, thời gian phản ứng SOC, thời hạn khắc phục lỗ hổng và số ngày bất biến phải được XOR phê duyệt theo rủi ro/hợp đồng; không gán một giá trị mẫu thành yêu cầu pháp luật.

5 Kịch bản kiểm thử T01 và T02

T01 Phân vùng và công khai dịch vụ

Đầu mối: Network. Căn cứ: 6.12.2.2–6.12.2.6.

Điều kiện trước thử: Danh mục IP/FQDN, luồng và cửa sổ thử đã duyệt.

Thực hiện: Kiểm kê endpoint từ ngoài và từ tenant; thử luồng được phép, luồng cấm, origin bypass WAF và Internet từ mạng quản trị.

Tiêu chí chấp nhận: Chỉ có endpoint/luồng được duyệt; quản trị, DB, OOB không lộ; chặn truy cập sai vùng.

Lưu bằng chứng: Rule export; log cho phép/từ chối; ảnh kết quả; phạm vi thử.

T02 Cách ly tenant

Đầu mối: Platform và Network. Căn cứ: 6.4.2.3; 6.12.

Điều kiện trước thử: Hai project và dữ liệu giả lập, tài khoản phân quyền rõ.

Thực hiện: Thử API/list/read/write, metadata, console, attach/snapshot/restore, object ACL và traffic từ A tới B; ghi từng trường hợp.

Tiêu chí chấp nhận: Không đọc, sửa hoặc quản trị chéo tenant; không thấy dữ liệu dư khi cấp lại tài nguyên.

Lưu bằng chứng: Request ID; log; cấu hình; biên bản từng bề mặt.

6 Kịch bản kiểm thử T03 và T04

T03 MFA và đặc quyền

Đầu mối: IAM. Căn cứ: 6.6; 6.12.2.5.

Điều kiện trước thử: Tài khoản thử, ticket và tài khoản khẩn cấp trong phạm vi.

Thực hiện: Thử thiếu MFA, thiết bị lạ, quyền hết hạn, bỏ qua PAM; thử cấp/thu hồi; kiểm tra một phiên khẩn cấp.

Tiêu chí chấp nhận: Đúng người/đích/thời hạn; phiên truy vết được; các đường bị cấm bị chặn; khẩn cấp được hậu kiểm.

Lưu bằng chứng: Policy; log IdP/VPN/PAM; ticket; bản ghi phiên.

T04 Dữ liệu và khóa

Đầu mối: Quản trị khóa. Căn cứ: 6.4.2.4–6.4.2.10.

Điều kiện trước thử: Dữ liệu thử, bản sao khóa và phương án quay lại được duyệt.

Thực hiện: Kiểm tra mã hóa lưu/truyền; hai lớp hoặc tương đương; thử sai quyền giải mã, luân chuyển/thu hồi/restore khóa và xác minh chữ ký.

Tiêu chí chấp nhận: Dữ liệu và khóa được bảo vệ theo phân loại; không có quyền giải mã ngoài ma trận; khôi phục không mất khả năng đọc.

Lưu bằng chứng: Cấu hình; log KMS; biên bản kiểm tra; không chụp khóa/bí mật.

7 Kịch bản kiểm thử T05 và T06

T05 Nhật ký và cảnh báo

Đầu mối: SOC. Căn cứ: 6.8; 6.13.

Điều kiện trước thử: Ma trận nguồn log, tài khoản thử, truy cập kho theo quyền.

Thực hiện: Tạo mỗi loại sự kiện; tìm actor/tenant/thời gian; ngắt nguồn thử; kiểm tra lưu giữ đủ 6 tháng và thử sửa/xóa log bằng quyền cloud admin.

Tiêu chí chấp nhận: Đủ trường và nguồn; có cảnh báo mất nguồn; kho tách vùng; bảo vệ sửa/xóa hoạt động; retention được chứng minh.

Lưu bằng chứng: Mẫu log đã che dữ liệu; truy vấn theo mốc; ticket ngoài giờ.

T06 EDR và DLP

Đầu mối: SecOps. Căn cứ: 6.4.2.8; 6.10.

Điều kiện trước thử: Mẫu thử an toàn của sản phẩm; máy/tệp giả lập.

Thực hiện: Thử phát hiện hành vi và kênh thất thoát áp dụng; kiểm tra gửi SIEM, cô lập, hoàn tác và tương thích ứng dụng.

Tiêu chí chấp nhận: Phát hiện/chặn theo chính sách; có người xử lý; không gây tác động ngoài phạm vi.

Lưu bằng chứng: Agent state; cảnh báo; ticket; biên bản xử lý.

8 Kịch bản kiểm thử T07 và T08

T07 Lỗi thành phần HA

Đầu mối: Hạ tầng và Platform. Căn cứ: 6.12.2.2.

Điều kiện trước thử: Kế hoạch bảo trì, ngưỡng chấp nhận, tải thử và rollback.

Thực hiện: Lần lượt thử mất controller, compute, storage node, NIC, FW/LB, ISP theo thiết kế; đo và xác minh dữ liệu.

Tiêu chí chấp nhận: Đạt ngưỡng đã phê duyệt; không mất nhất quán; đủ năng lực còn lại và không phát sinh điểm lỗi đơn chưa kiểm soát.

Lưu bằng chứng: Timeline; metrics; cluster log; kiểm tra dữ liệu.

T08 Sao lưu và restore

Đầu mối: Backup. Căn cứ: 6.11.2.1–6.11.2.5.

Điều kiện trước thử: Kho restore cô lập, catalog dữ liệu và khóa cần thiết.

Thực hiện: Chọn bản sao VM/DB/config/khóa; thử truy cập/xóa theo vai trò; restore và kiểm tra checksum, đăng nhập, dữ liệu nghiệp vụ.

Tiêu chí chấp nhận: Bản sao độc lập khôi phục được; kiểm tra bất biến nếu thiết kế dùng; thời gian và dữ liệu mất nằm trong chỉ tiêu đã chốt.

Lưu bằng chứng: Job ID; bản sao được chọn; log; checksum; số đo.

9 Kịch bản kiểm thử T09 và T10

T09 Mất DC và chuyển về

Đầu mối: Chỉ huy DR. Căn cứ: BIA; 6.11; 6.12.

Điều kiện trước thử: BIA/RPO/RTO đã duyệt, cửa sổ thử, kênh phối hợp và rollback.

Thực hiện: Xác nhận replica; cô lập nguồn ghi DC; kích hoạt DR cùng IAM/DNS/KMS; thử nghiệp vụ; đồng bộ và chuyển về theo runbook.

Tiêu chí chấp nhận: Đạt RPO/RTO từng dịch vụ; không dual writer; đủ công suất; failback được kiểm chứng.

Lưu bằng chứng: Timeline; fencing log; lag; đối soát DB; phê duyệt chuyển đổi.

T10 Khởi động nguội

Đầu mối: Platform. Căn cứ: Thiết kế XOR; tham khảo dự thảo 5.3.9.

Điều kiện trước thử: Môi trường khôi phục riêng; tài liệu và bí mật khẩn cấp có thể tiếp cận.

Thực hiện: Giả lập dừng toàn nền tảng; lần lượt dựng dịch vụ theo dependency; không dùng bí mật chỉ nằm trên hệ thống đang dừng.

Tiêu chí chấp nhận: Dựng lại được control plane và dịch vụ mẫu; phát hiện/xử lý mọi vòng phụ thuộc.

Lưu bằng chứng: Dependency map; thứ tự bước; log; biên bản truy cập khẩn cấp.

10 Kịch bản kiểm thử T11 và T12

T11 Phát hành an toàn

Đầu mối: DevSecOps. Căn cứ: 6.16.

Điều kiện trước thử: Pipeline thử, artifact đúng/sai chữ ký và bản rollback.

Thực hiện: Thử image chưa duyệt/sai digest, secret scan, quyền runner dev; phát hành bản hợp lệ rồi hoàn tác.

Tiêu chí chấp nhận: Gate từ chối bản không đạt; bản được duyệt truy nguyên được; rollback thành công.

Lưu bằng chứng: Pipeline run; review; SAST/SCA; digest; biên bản rollback.

T12 Pentest và đánh giá độc lập

Đầu mối: Đơn vị đánh giá. Căn cứ: 6.18; 6.12.2.7.

Điều kiện trước thử: ROE ký, phạm vi IP/tenant, lịch, dữ liệu và điều kiện dừng.

Thực hiện: Kiểm thử từ ngoài và trong; kiểm tra quyền nội bộ/cách ly; lập phát hiện; xử lý và retest; ghi giới hạn phương pháp.

Tiêu chí chấp nhận: Kết luận theo tiêu chí và phạm vi đã phê duyệt; phát hiện được xử lý hoặc quản lý đúng thẩm quyền; không tự đánh dấu đạt khi thiếu retest.

Lưu bằng chứng: Báo cáo ký; ROE; ticket; retest; ý kiến nghiệm thu.

11 Biên bản và điều kiện chuyển hồ sơ

Trường biên bản	Nội dung cần ghi
Mã và phạm vi	Mã T/TC/CL; site; asset ID; project; bản dựng; ngày giờ; cửa sổ thử.
Thành phần tham gia	Người thực hiện, người chứng kiến, người xác nhận và phạm vi quyền.
Kết quả	Điều kiện đầu vào, bước đã làm, số đo, kết quả so với tiêu chí và mã EV.
Tồn tại	Mô tả, ảnh hưởng, mức ưu tiên theo rủi ro, đầu mối và hạn.
Retest	Ngày thử lại, phiên bản mới, kết quả, bằng chứng và người xác nhận.
Kết luận	Đạt/Không đạt/Chưa đủ bằng chứng trong phạm vi cụ thể; các giới hạn và ngoại lệ.

Đợt rà soát được đóng khi phạm vi và danh mục đã chốt, các mục áp dụng có bằng chứng được xác minh, kết quả thử được lưu, phát hiện được xử lý theo quyết định đúng thẩm quyền. Việc chấp nhận rủi ro không tự thay thế một yêu cầu bắt buộc chưa đáp ứng.

Trước gửi thẩm định: chuyển dữ liệu thực tế sang Bộ 2; đính kèm thiết kế đã phê duyệt hoặc tài liệu tương đương; hoàn thiện đánh giá rủi ro chi tiết và ý kiến chuyên trách. Không gửi bản còn [CẦN ĐIỀN], không dùng bảng tổng hợp Excel như quyết định phê duyệt.

Nguồn tham chiếu

[S1] Nghị định 331/2026/NĐ-CP: Điều 14, 18, 20–24 và Phụ lục. Nguồn chính thức: https://vanban.chinhphu.vn/?docid=219243&pageid=27160

[S2] TCVN 14423:2026: Điều 6, trang 58–81; Phụ lục A.4, trang 109–111. Đã đối chiếu bản được cấp phép nội bộ. Diễn giải trong hồ sơ phục vụ áp dụng tại XOR; không đính kèm bản tiêu chuẩn có bản quyền.

Dự thảo TCVN Cloud năm 2026 chỉ dùng để rà soát thiết kế bổ sung. Các điểm bổ sung không tạo kết luận Hạng B/Mức 4 và không thay checklist toàn bộ dự thảo.